Day 9 — Role-Based Authorization (RBAC)

Objective

Enforce **role-based access control** on secured endpoints using JWT claims and authorization policies.

1. Added Authorization Policies (Program.cs)

Defined role-based policies to centralize access rules:

```
builder.Services.AddAuthorization(options =>
{
    options.AddPolicy("AdminOnly", policy =>
        policy.RequireRole("Admin"));

    options.AddPolicy("UserOnly", policy =>
        policy.RequireRole("User"));
});
```

- Avoid hardcoding roles across controllers
- Enables scalable access control

2. Verified Role Claim in JWT

JWT already includes role:

```
new Claim(ClaimTypes.Role, user.Role)
```

- Ensures authorization middleware can evaluate roles correctly

3. Applied Authorization to Controllers

1. AIController

```
[Authorize]
[HttpPost("generate")]
```

- Restricted to authenticated users
- Removed earlier incorrect policy (UserOnly) which blocked Admin

2. SummarizeController

```
[Authorize]
```

- Consistent with AI feature access (authenticated users)

3. UsersController

```
[Authorize(Policy = "AdminOnly")]
```

- Restricted sensitive operations (create/view users) to Admin only

4. TestController (RBAC validation)

[Authorize] → /secure

[Authorize(Policy = "AdminOnly")] → /admin

- Used for testing authentication vs authorization

4. AuthController

[AllowAnonymous]

- Login remains publicly accessible

Testing (Swagger)

#	Endpoint	Token	Role	Request	Expected	Result	Status
1	POST /api/AI/generate	❌ No	—	Prompt	401 Unauthorized	401	✅
2	POST /api/AI/generate	✅ Yes	Admin	Prompt	200 OK	200	✅
3	POST /api/summarize	❌ No	—	Text	401 Unauthorized	401	✅
4	POST /api/summarize	✅ Yes	Admin	Text	200 OK	200	✅
5	GET /api/users	❌ No	—	—	401 Unauthorized	401	✅
6	POST /api/users	❌ No	—	User Data	401 Unauthorized	401	✅
7	GET /api/users	✅ Yes	Admin	—	200 OK	200	✅
8	POST /api/users	✅ Yes	Admin	User Data	201 Created	201	✅
9	GET /api/test/secure	❌ No	—	—	401 Unauthorized	401	✅
10	GET /api/test/secure	✅ Yes	Admin	—	200 OK	200	✅
11	GET /api/test/admin	❌ No	—	—	401 Unauthorized	401	✅
12	GET /api/test/admin	✅ Yes	Admin	—	200 OK	200	✅

Key Observations

- All protected endpoints return **401 without token** ✓
- Authenticated requests return **200/201 as expected** ✓
- Admin-only endpoints correctly allow Admin ✓
- AI & Summarize accessible to authenticated users ✓
- RBAC enforcement is consistent across controllers ✓

Final State

Controller	Access
Auth	Public
AI	Authenticated users
Summarize	Authenticated users
Users	Admin only
Test	Mixed (for validation)